

we will be able to locate all of the systems on the network, and the systems will answer with their IP and MAC addresses.

Select a suitable range for your target network.

ARP Poison

Now that we have all of the machines, IP addresses, and MAC addresses on the network thanks to the ARP scan, we can poison the ARP. Our attack system stands between the RDP server and the RDP client by poisoning the ARP. As a result, all communications from either machine must pass via our attack machine. On Cain, click the Sniffer button, then the Sniffer tab, then the Hosts tab at the bottom, then the blue + on the top menu, then the Radio button, choose the target IP range, and click OK.

Choose Server and Client to Poison

Choose the APR button next to the hosts tab you used earlier, then press the blue Add button, select the targets, and press OK.

Connect RDP Client to Server

We must now wait for the RDP client to establish a connection to the RDP server. This is most likely to occur when a customer contacts tech help and requests that tech support configure and demonstrate something on their machine. As you may expect, this will take some time. When they do, we'll be able to intercept their traffic.

Capture Network Traffic

All traffic between the RDP server and the RDP client will flow via our attack system if we use our Cain and Abel MiTM attack. Cain and Abel is currently recording the entire session and saving it to the far right column as a file. We can now open the decrypted file in Notepad by right-clicking on the filename and selecting View.

Search for Traffic

Now that all RDP traffic is passing through our attack system, we may look for traffic that is of interest to us. For RDP, we'd like to have the sysadmin password. We will most likely be able to utilise RDP on any of the network's workstations if we can find the sysadmin password for RDP, as the sysadmin would normally set up RDP with the same password on every system for simplicity.